GRC103 —
Technical Risk Treatment - Implementing and Validating Security Controls

Week 3 Practical Lab Report

Student Name: Imelda Sanya
Registration Number:C11/26/CGRCE/17576

C2-Safaricom Internal Standard

1. Management summary

The assessment looked at a small internal document portal used for the Northbridge Services training scenario. The practical work focused on four risks: an unnecessary legacy service, an exposed archive directory, unauthorised network access and loss of portal content. A separate decision was documented for temporarily retaining HTTP within the isolated lab.

The work produced several clear results. The legacy Python service was stopped and disabled, and a socket check showed that port 8080 was no longer listening. The archive record was moved out of the web root and its permissions were restricted. Nginx was configured to deny requests to the old archive URL; both directory and direct-file requests returned HTTP 403, while the public home page continued to return HTTP 200.

UFW was configured to deny incoming traffic by default and to allow SSH and HTTP only from the approved Kali address. A second, temporary source address was used to test the restriction. The approved address reached the portal, the test address timed out, and the Ubuntu firewall log contained a matching UFW BLOCK entry.

A copy of the portal content was created on the Ubuntu VM. The original file and backup produced matching SHA-256 values. After the public index file was deleted, the website returned HTTP 403. The file was restored, the checksum manifest reported OK, and the portal returned HTTP 200 again.

The practical work demonstrates recovery from accidental file deletion, but the backup was stored on the same VM as the original. It would not protect against complete VM, disk or host failure. A managed off-host backup is therefore recommended for consideration. The report distinguishes completed lab tests from proposed arrangements and simulated approvals.

Management recommendations

Maintain the retired state of the legacy service; keep archive content outside the web root; review firewall rules and blocked-traffic logs; arrange off-host backups with periodic restore tests; and implement HTTPS before the portal is used outside the isolated training environment.

2. Scope, objectives and method

The assignment called for a two-VM local lab using Ubuntu Server and Kali Linux on an isolated internal or host-only network. Package installation was performed while temporary NAT connectivity was available. The VMs were then returned to the VMware “Private to my Mac” network before the lab services were tested. No bridged networking or public exposure was used.

The Ubuntu server used 172.16.182.130/24 and Kali used 172.16.182.128/24 during the recorded tests. The private-network interface names were ens33 on Ubuntu and eth0 on Kali. SSH from Kali was used for administration after the network change. The assignment recommends using the Ubuntu VM console for firewall changes; in this exercise, UFW was configured through the established SSH session after an explicit source-specific SSH allow rule was added. This is a procedural deviation worth recording.

The practical method was to establish the web service and dummy archive, capture the observed baseline, apply one treatment at a time, and verify both allowed and denied behaviour. Evidence consisted of terminal output, HTTP responses, service status, socket inspection and firewall logs.

C2-Safaricom Internal Standard

3. Baseline environment and findings

The Ubuntu VM hosted Nginx on TCP port 80. The public page displayed the fictional Northbridge Services landing page. An archive directory was initially published through Nginx with autoindex enabled, and the dummy record could be retrieved directly. The archive record contained training-only information and no real personal or business data.

A Python-based legacy HTTP service was created as a systemd unit and configured to listen on 0.0.0.0:8080. The service was confirmed active on Ubuntu. However, UFW had already been enabled with a default-deny incoming policy and only source-specific SSH and HTTP allow rules. Consequently, the Kali Nmap scan reported port 80 open and port 8080 filtered; the curl request to port 8080 timed out. The service was running locally, but it was not reachable from Kali. This is an important distinction: the evidence does not support claiming that port 8080 was reachable during the network baseline.

The baseline Nmap command initially appeared to hang when service detection was attempted. A bounded TCP connect scan was then used and completed successfully. It showed 80/tcp open and 8080/tcp filtered. The website and archive tests from Kali confirmed that the root page, archive listing and dummy archive file were accessible before mitigation.

4. Risk register and scoring

ID / risk	Initial L×I	Initial level	Treatment and evidence	Residual L×I	Residual level
R1 – Unnecessary legacy service	4×4 = 16	High	Avoidance: service stopped and disabled; no listener remained on 8080.	1×4 = 4	Low
R2 – Exposed archive	4×4 = 16	High	Mitigation: moved to /srv/grc-private, restricted permissions, Nginx denies /archive/; HTTP 403.	1×4 = 4	Low
R3 – Unauthorised network access	3×5 = 15	High	Mitigation: UFW default deny; source-specific SSH/HTTP allows; unapproved source timed out and UFW logged BLOCK.	1×5 = 5	Medium
R4 – Loss of portal content	3×4 = 12	High	Mitigation: local backup, SHA-256 manifest, restore test and successful HTTP recovery; same-VM limitation remains.	2×4 = 8	Medium

The assignment specifies a 1–5 likelihood scale and a 1–5 impact scale. The score is likelihood multiplied by impact. Scores of 1–4 are Low, 5–9 Medium, 10–16 High and 17–25 Critical. These are classroom ordinal ratings, not statistical probabilities or monetary values. Initial and residual ratings below are reasoned assessment judgements based on the observed lab results; they are not measured frequencies.

Initial level

Treatment and evidence

Residual L×I				
Residual level				
R1 – Unnecessary legacy service	4×4 = 16	High	Avoidance: systemd service stopped and disabled; no listener remained on 8080.	1×4 = 4
Low				
R2 – Exposed archive	4×4 = 16	High	Mitigation: record moved to /srv/grc-private, permissions restricted, Nginx denies /archive/. HTTP tests returned 403.	1×4 = 4
Low				
R3 – Unauthorised network access	3×5 = 15	High	Mitigation: UFW default deny; source-specific SSH/HTTP allows; unauthorised source timed out and UFW logged BLOCK.	1×5 = 5
Medium				
R4 – Loss of portal content	3×4 = 12	High	Mitigation: local backup, SHA-256 manifest, restore test and successful HTTP recovery. Same-VM backup limitation remains.	2×4 = 8
Medium				

Risk owner for the exercise: Northbridge Services IT/Security Manager (proposed role). These residual ratings should be reviewed by the risk owner and adjusted if the service scope, data classification or network exposure changes.

5. Risk avoidance – R1 legacy service

The proposed change was to retire the unnecessary legacy endpoint while retaining the approved web portal. The expected business impact was limited to removal of the unused training endpoint; the approved Nginx service was to remain available. The simulated approval role was the IT/Security Manager. The test was to check the service state and listening sockets, then confirm that port 80 remained available. A rollback would have been to run systemctl enable --now grc-legacy if the service were genuinely required; the final lab state was to leave it disabled.

The command systemctl disable --now grc-legacy was executed. systemctl status showed inactive (dead) and disabled. A subsequent ss -lntp check showed Nginx listening on port 80 and no listener on port 8080. This confirms removal of the legacy listener. It does not eliminate risks to the remaining web service, which were addressed separately.

6. Risk mitigation – R2 archive exposure

The archive record was moved from the web directory to /srv/grc-private. The directory was set to mode 700 and the record to mode 600, restricting access to root. The Nginx location for /archive/ was changed to disable autoindex and explicitly deny all requests. Nginx configuration testing succeeded before the service was reloaded.

After the change, requests to /archive/ and /archive/record-001.txt returned HTTP 403 Forbidden. The public home page continued to return HTTP 200 OK. This is important because turning directory listing off by itself would not necessarily prevent a user who knows a file path from requesting that file directly; the explicit denial and moving the file outside the web root address both browsing and direct retrieval.

7. Risk mitigation – R3 network access and firewall logging

UFW was configured with default deny incoming and default allow outgoing. The allow rules permitted TCP port 22 and TCP port 80 only from Kali address 172.16.182.128. The firewall was enabled after these source-specific rules had been added. SSH remained available from Kali, and a fresh SSH connection succeeded after enabling UFW.

For the blocked-source test, a second address, 172.16.182.200/24, was temporarily added to Kali eth0 after duplicate-address detection produced no replies. A curl request explicitly bound to that source timed out. A request bound to the approved address 172.16.182.128 returned HTTP 200. The temporary address was removed after testing, and Kali returned to its original address.

The Ubuntu firewall log contained an entry with UFW BLOCK, source 172.16.182.200, destination port 80 and interface ens33. This corroborates the blocked-source test. Firewall-blocked packets do not reach Nginx, so they should appear in UFW/kernel logs rather than Nginx access logs. Permitted HTTP requests are expected to appear in Nginx access logs.

The UFW configuration also allowed SSH from Kali to support remote administration. This is an additional rule beyond the assignment's example HTTP rule. The assignment recommends using the Ubuntu console for firewall changes; this lab instead maintained a source-restricted SSH path. For a production environment, firewall administration should follow the organisation's approved console or out-of-band access procedure.

8. Detection, logging and operational handover

The firewall logging check was successful: the UFW log showed the blocked temporary source attempting TCP port 80. The practical evidence reviewed in the session confirms this firewall event. A full timestamp-correlated Nginx access-log extract was not separately captured, so this report does not claim a complete end-to-end log-correlation exercise.

Daily automated check; weekly

review

incident

Unexpected listening ports

Weekly and after changes

Any listener outside approved list: investigate

immediately

Backup and restore success

Backup owner / IT

Backup monitoring daily; restore

test quarterly

Missed backup or failed restore: escalate to IT/Security

Manager

Legacy service configuration

drift

Weekly

Service enabled or port 8080 listening: investigate

immediately

UFW blocked traffic

Security / IT operations

Weekly review; alert on unusual

volume

Repeated or unexpected attempts: review source and

scope

9. Backup and recovery – R4

A copy of /var/www/grc-lab/public was created under /srv/grc-backups/public. The original index.html and the backup copy produced the same SHA-256 digest: ee0ee1c296955fa5a032d9097fbc2571a0dfc05f81f4dd87bb9a69a507f239ec. A checksum manifest was saved as public-index.sha256.

The original index.html was deleted to simulate accidental loss. From Kali, the root request returned HTTP 403 rather than the anticipated 404. This occurred because the directory remained present, directory listing was disabled, and no index file remained. The file was restored from the backup. The checksum command returned public/index.html: OK, and the public website again returned HTTP 200 with the Northbridge page.

The observed test proves that the local backup can restore a deleted file. The backup was stored on the same Ubuntu VM, however, and is not a substitute for an off-host backup. The exercise did not capture reliable start and end timestamps for the recovery operation, so a precise recovery time or measured RTO is not claimed.

10. Risk transfer – managed backup proposal

The assignment's fictional managed-backup offer is $120 setup plus $20 per month, giving a first-year cost of $360. No service was purchased and no contract was signed. The proposal is to use a managed provider for scheduled off-host backups and restoration support, while Northbridge retains responsibility for defining the backup scope, classifying information, approving access and verifying restores.

Proposed division of responsibilities

Maintain the backup platform; perform scheduled backups of agreed data; protect stored copies; notify the customer of failures or relevant incidents; provide restoration support.

Identify and classify data; approve backup scope and access; review backup reports; request restores; test restored data; retain evidence and monitor service performance.

Proposed service clause

The managed backup provider shall perform scheduled backups of the data agreed with Northbridge Services, protect backup copies against unauthorised access, and provide restoration support on request. The provider shall notify Northbridge Services of backup failures or security incidents affecting the service. Northbridge Services shall remain responsible for data classification, access authorisation, backup scope approval and periodic restoration testing. The service agreement should specify recovery targets, retention periods, evidence availability, incident notification arrangements, data retrieval and secure deletion on termination.

Transfer does not remove all risk. Provider outages, configuration errors, compromised credentials, failed restores and unclear service boundaries remain possible. Northbridge should require documented restore testing, evidence retention and an exit process before relying on the service.

11. Risk acceptance – temporary HTTP

The assignment asks whether plain HTTP may be temporarily retained on the isolated lab network with dummy data only. The proposed decision is conditional acceptance for the classroom environment, not approval for production use. The proposed owner is the Northbridge IT/Security Manager, and the approval is simulated for this exercise.

Risk

HTTP traffic is not encrypted in transit.

Scope

Isolated VMware private network; fictional training data only.

Duration

14 days from the simulated approval date; review at expiry.

Controls

UFW source restrictions; no bridged/public exposure; no real sensitive data.

Immediate review triggers

Any external connectivity, real data, broader user access or change in purpose.

Approval

Simulated approval only; management sign-off not obtained.

If the environment becomes accessible outside the isolated lab, or if real business or personal information is introduced, the acceptance should end and the service should be escalated for HTTPS or another suitable control. The 14-day expiry is a proposed governance condition, not an observed technical setting.

12. Cost comparison and ALE

labour plus annual recurring cost. They exclude taxes, licensing beyond the stated amounts, infrastructure, staff overheads outside the stated labour, data egress and any additional implementation work.

A – Hardening

4 hours × $25 + $50 annual maintenance

$150

B – Managed backup

$120 setup + ($20 × 12 months)

$360

C – TLS deployment

3 hours × $25 + $25 annual maintenance

$100

A practical recommendation is to complete hardening (A) and TLS deployment (C) as the first-year technical improvements, at a combined illustrative cost of $250. The managed backup option (B), at $360 in year one, should also be considered because the lab backup is on the same VM as the live data. Implementing all three options would total $610 in the first year, based on the supplied assumptions.

Illustrative backup-only ALE scenario

This calculation is separate from the ordinal risk scores. It uses only the assignment's illustrative assumptions: annual rate of occurrence (ARO) 0.2, baseline loss per event $5,000, and loss per event after a tested recovery control $1,000.

Baseline ALE

0.2 × $5,000

$1,000 per year

Residual ALE

0.2 × $1,000

$200 per year

Annual estimated benefit

$1,000 − $200

$800

First-year net benefit for B

$800 − $360 first-year cost

$440

These are assumptions for the classroom model, not measured Northbridge loss data. The successful file restoration does not validate the ARO or dollar-loss assumptions. The ALE benefit should not be added to other control benefits if they overlap, and the ordinal risk scores must not be converted into monetary savings.

13. Residual risk and conclusion

The legacy service and archive publication risks were reduced to Low in the proposed residual assessment because the specific exposures were removed and the relevant checks passed. Unauthorised network access was reduced to Medium because source-based firewall controls were tested, but firewall configuration and ongoing access management still require review. Portal-content loss was reduced to Medium because restoration succeeded, while same-host backup limitations remain. Temporary HTTP remains a Medium residual risk under the proposed, time-limited acceptance.

The lab showed that the controls were not treated as complete merely because they had been configured. The work included checks of service state, listening sockets, HTTP status codes, firewall behaviour, log entries and file integrity. The strongest remaining improvement is to move backups off the Ubuntu VM and to implement HTTPS before any use beyond the isolated training environment.

Overall, the Northbridge portal was retained while the unnecessary service and exposed archive path were removed. Access from an unapproved source was blocked and logged, and the public page was recovered after a simulated deletion. The results provide a practical basis for management to review the residual risks and approve the proposed next steps.

14. Evidence and limitations

Screenshots and supporting captures are supplied in the accompanying evidence ZIP. The evidence index maps each capture to the relevant task. The screenshots include setup, configuration, test results and some troubleshooting captures; not every troubleshooting capture is relied upon as proof of a successful control.

The main limitations are: (1) UFW was enabled before the network baseline, so port 8080 was filtered from Kali even though the legacy service was running locally; (2) firewall administration was performed over SSH rather than exclusively from the Ubuntu console, with a source-specific SSH allow rule in place; (3) the backup was stored on the same VM; (4) a precise recovery duration was not recorded; and (5) a complete timestamp-correlated Nginx and UFW log analysis was not captured. These limitations are disclosed rather than filled with assumed results.

References

Primary source: ICDFA, GRC103 Risk Assessment and Management Techniques, Module 3 – Technical Risk Treatment Lab (assignment brief supplied for this exercise). Technical implementation was carried out in the local Ubuntu and Kali lab. The cost figures and ALE assumptions are taken from the assignment brief.

Supporting technical documentation named in the assignment: Ubuntu Server firewall documentation (ubuntu.com/server/docs/firewalls); NGINX autoindex module documentation (nginx.org/en/docs/http/ngx_http_autoindex_module.html); NGINX log module documentation (nginx.org/en/docs/http/ngx_http_log_module.html).

Supporting tables

Baseline test results

Check	Observed result	Evidence interpretation
HTTP root	Northbridge page returned successfully	Approved web service was available
Archive listing	Directory listing showed record-001.txt	Archive publication and browsing were exposed
Direct archive file	Dummy record content was returned	Direct retrieval was possible without authentication
Nmap 80/tcp	Open	Nginx was reachable from Kali
Nmap 8080/tcp	Filtered	UFW prevented Kali from reaching the legacy listener
Legacy curl	Timed out	Consistent with firewall filtering

Cost comparison

Option	Calculation	First-year cost
A – Hardening	4 hours × $25 + $50 annual maintenance	$150
B – Managed backup	$120 setup + ($20 × 12 months)	$360
C – TLS deployment	3 hours × $25 + $25 annual maintenance	$100

Illustrative backup-only ALE scenario

Measure	Calculation	Result
Baseline ALE	0.2 × $5,000	$1,000 per year
Residual ALE	0.2 × $1,000	$200 per year
Annual estimated benefit	$1,000 − $200	$800
First-year net benefit for B	$800 − $360 first-year cost	$440

Appendix A – Lab Screenshots

The following evidence consists only of the 20 screenshots supplied for this update. Captions describe the visible command output and observed results.

Figure A01. Ubuntu server network configuration showing ens33 UP with address 172.16.182.130/24.

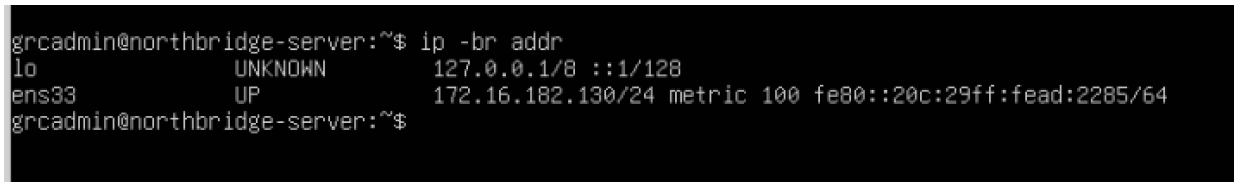


Figure A02. Kali network configuration showing eth0 UP with address 172.16.182.128/24.

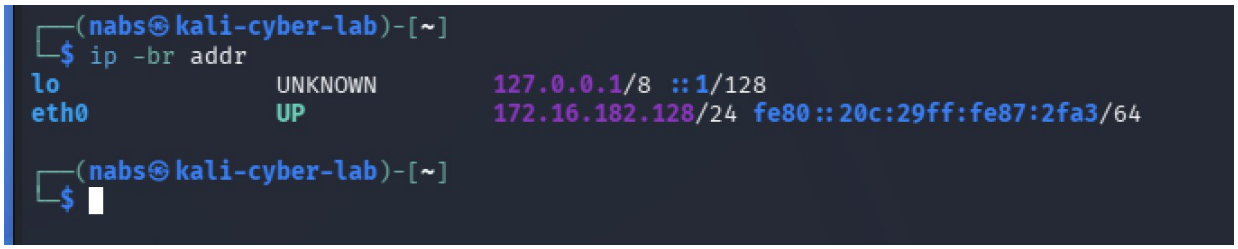


Figure A03. Successful SSH connection from Kali to the Ubuntu server.

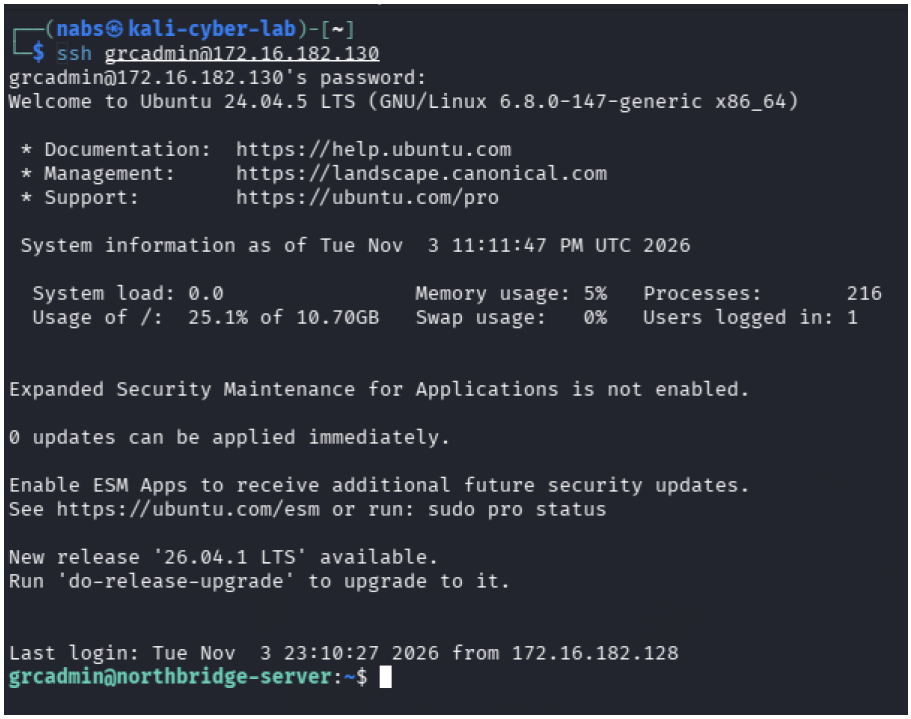


Figure A04. Ubuntu package index update and package upgrade output.

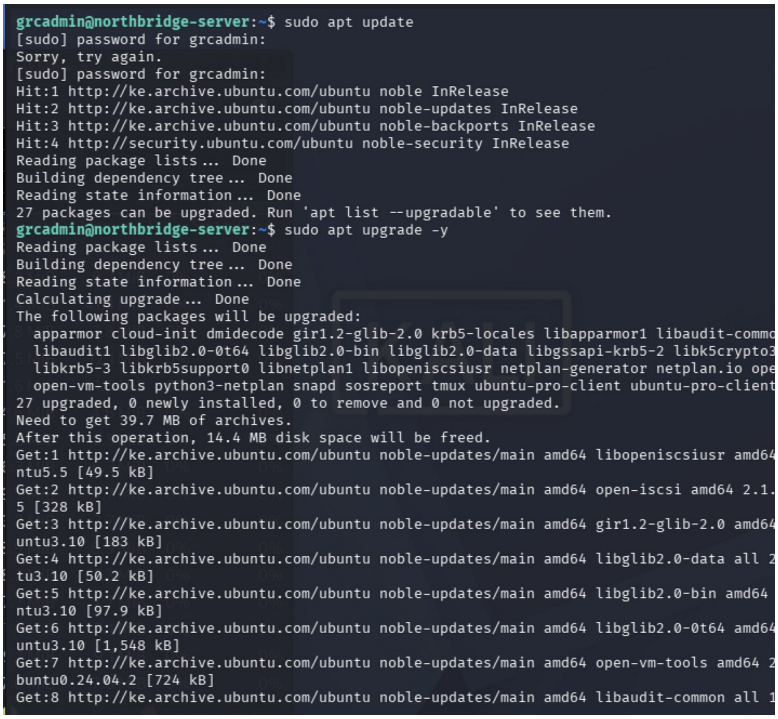


Figure A05. UFW enabled and verified with default deny incoming, allow outgoing, and source-specific SSH/HTTP rules.

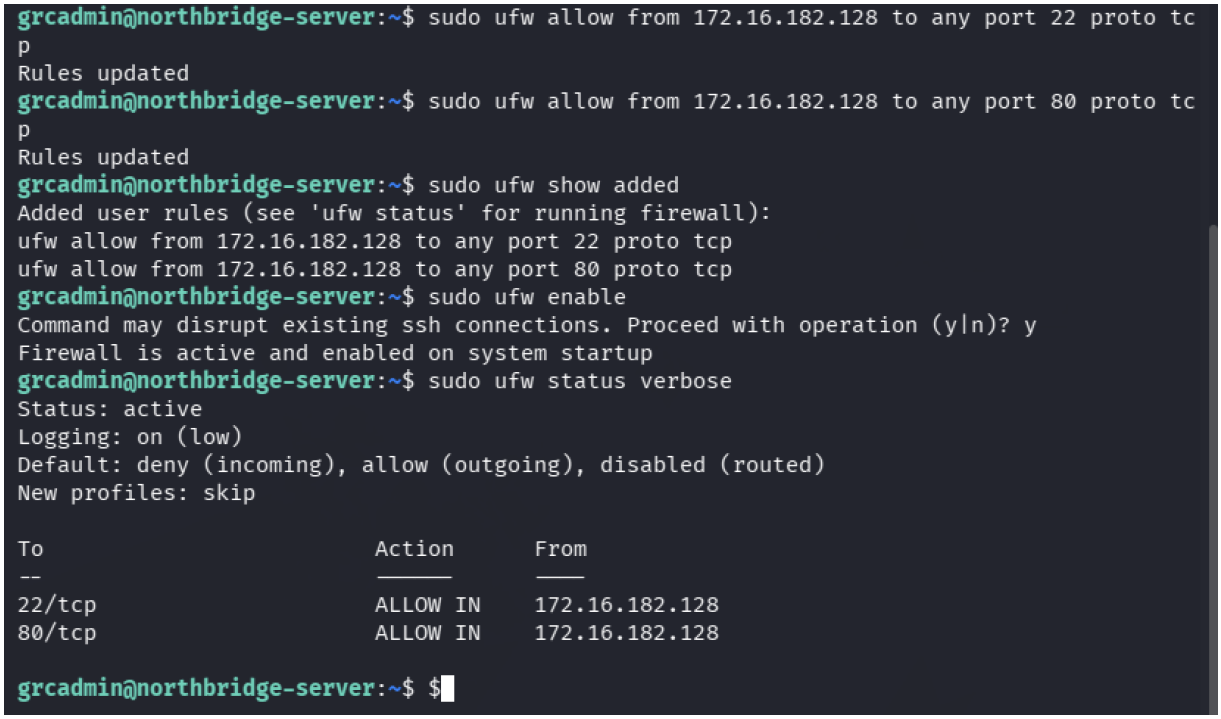


Figure A06. SSH connectivity confirmed after the firewall rules were enabled.

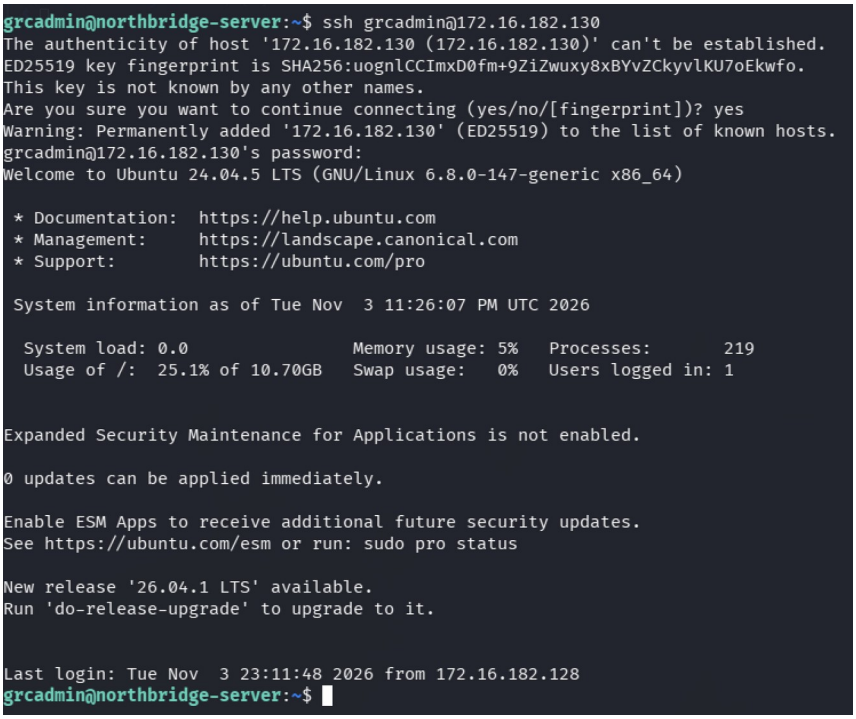


Figure A07. Nginx version and service status showing the web server active and running.

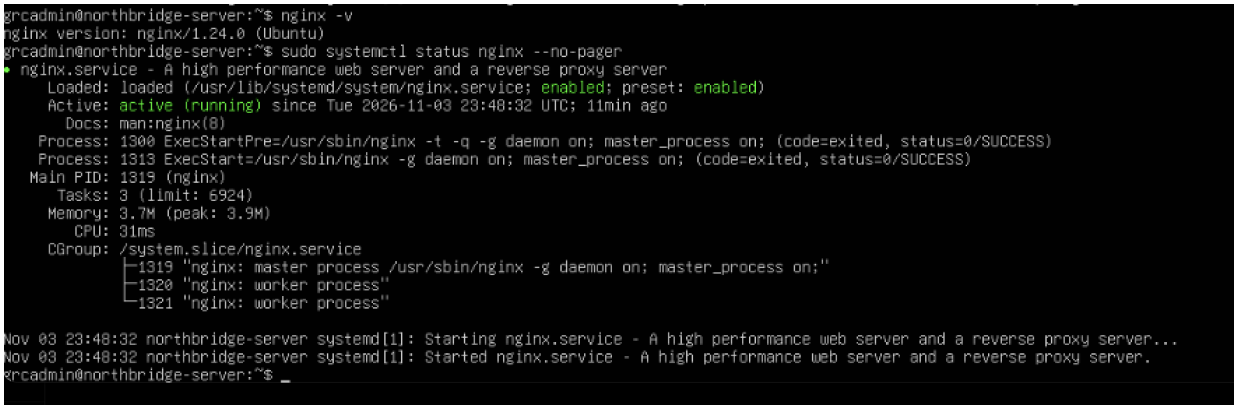


Figure A08. Creation of the fictional dummy archive record used for the exposure test.

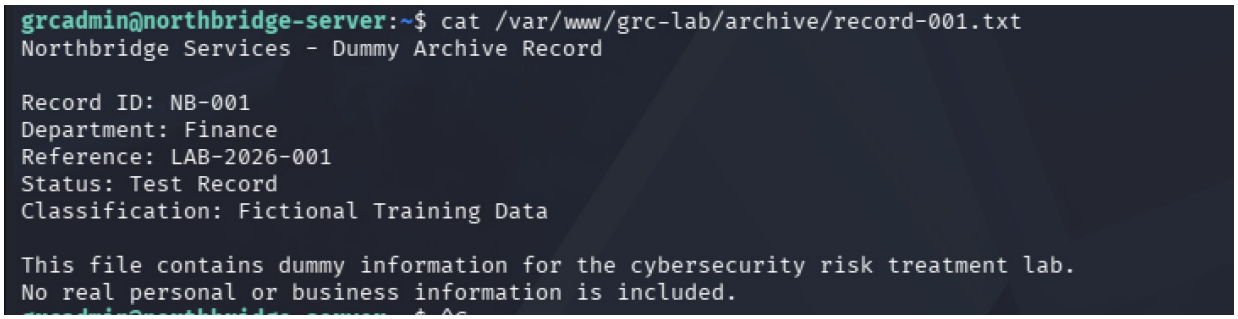


Figure A09. Nginx configuration validation and service reload during the lab setup.

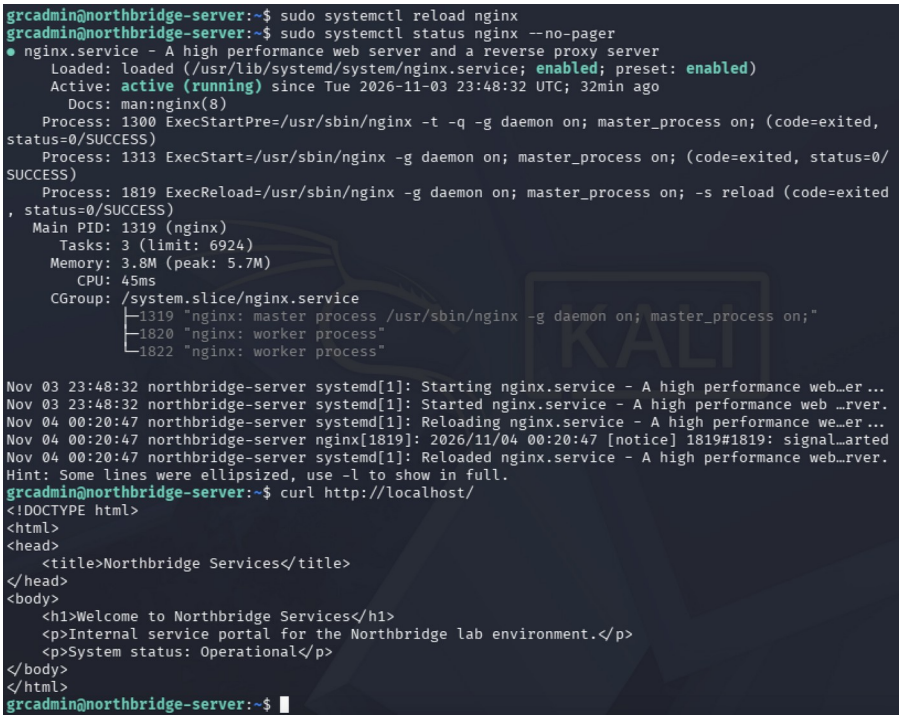


Figure A10. Baseline test showing the archive directory listing and direct retrieval of the dummy record.

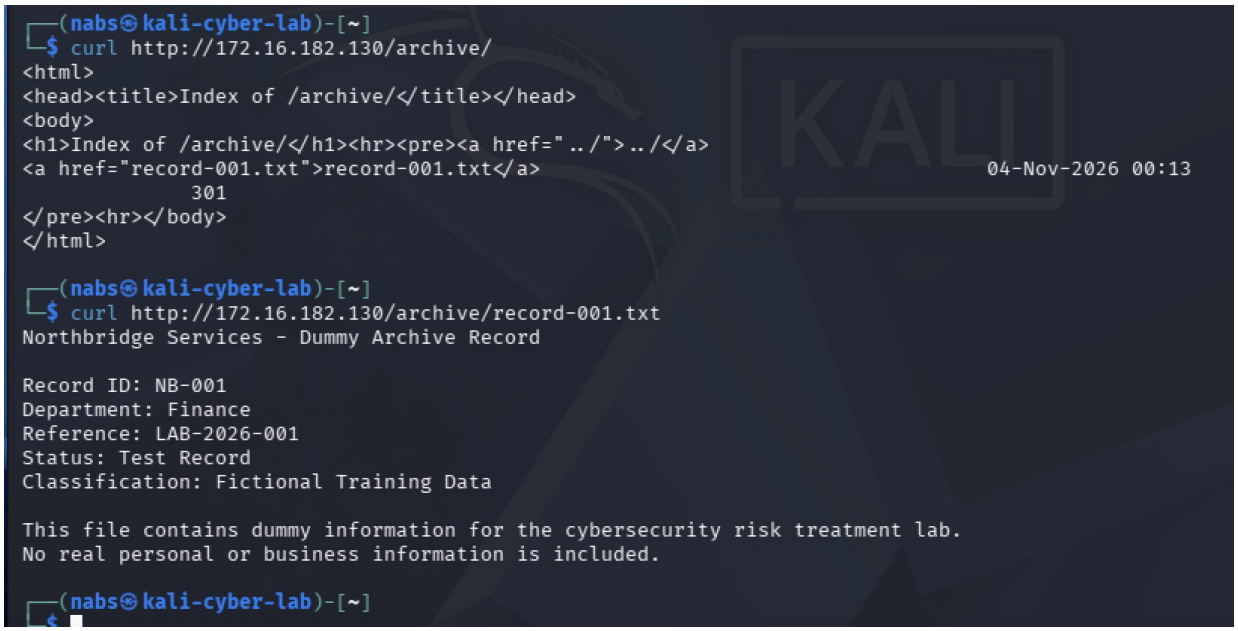


Figure A11. Bounded baseline Nmap scan: 80/tcp open and 8080/tcp filtered.

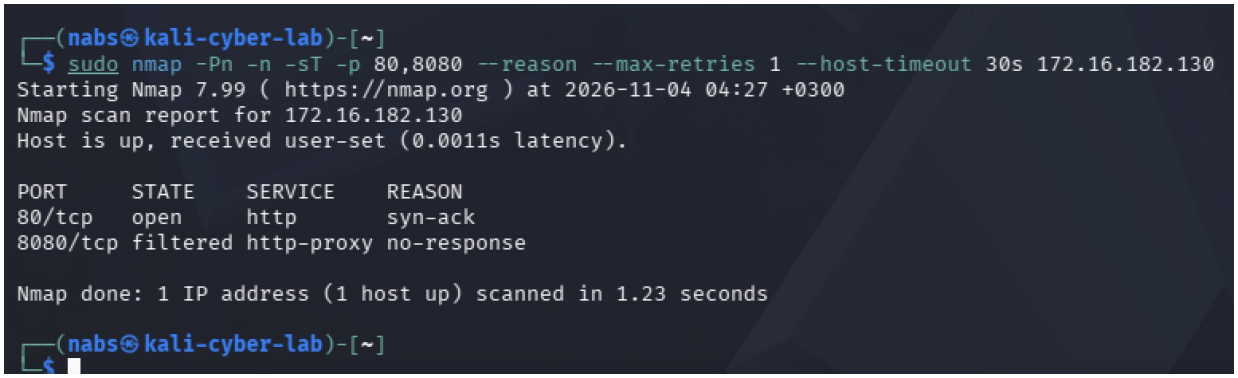


Figure A12. Legacy Python service shown active and running before retirement.

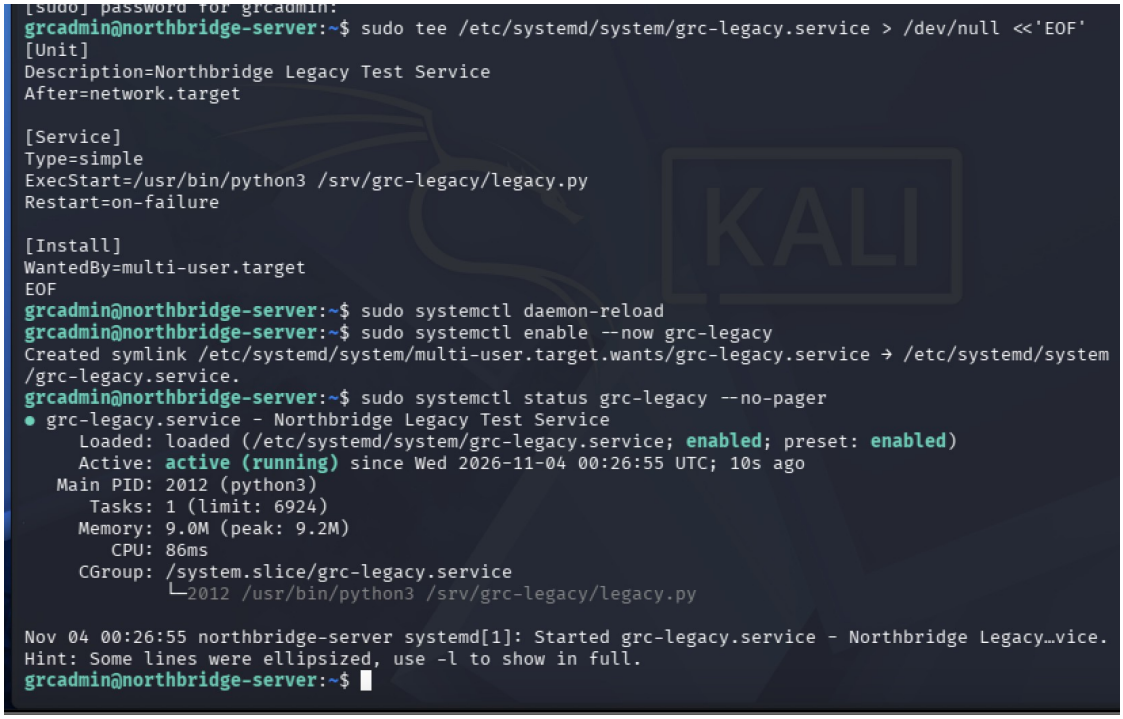


Figure A13. Kali curl request to the legacy endpoint timed out during baseline testing.

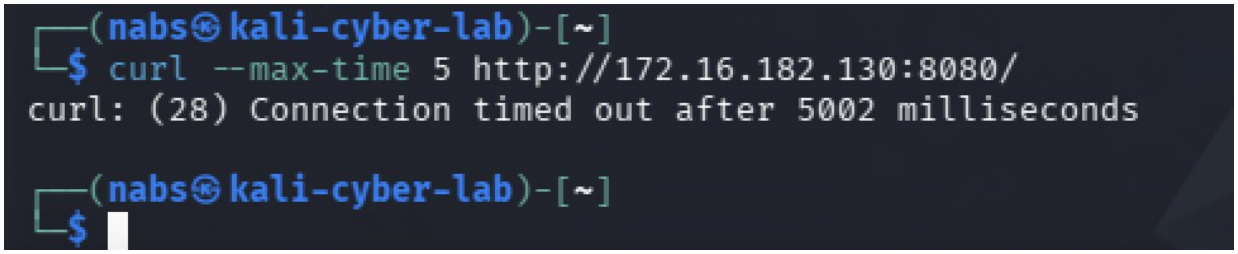


Figure A14. Legacy systemd service stopped and disabled.

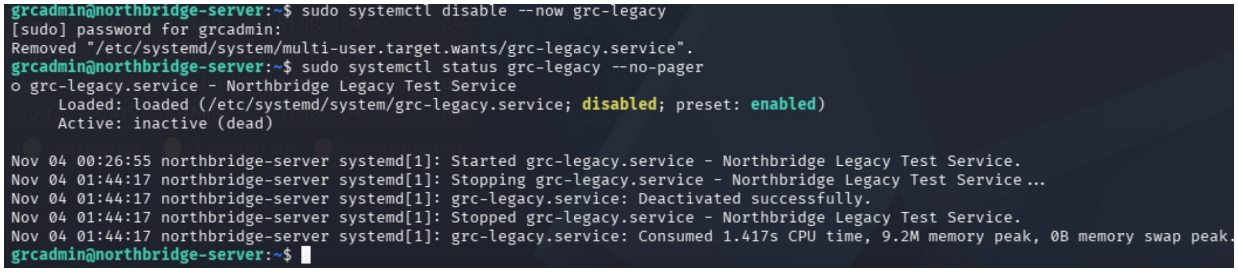


Figure A15. Socket check showing Nginx listening on port 80 and no listener on port 8080.

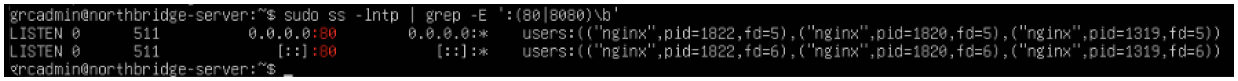


Figure A16. Public Northbridge portal remained accessible after the hardening changes.

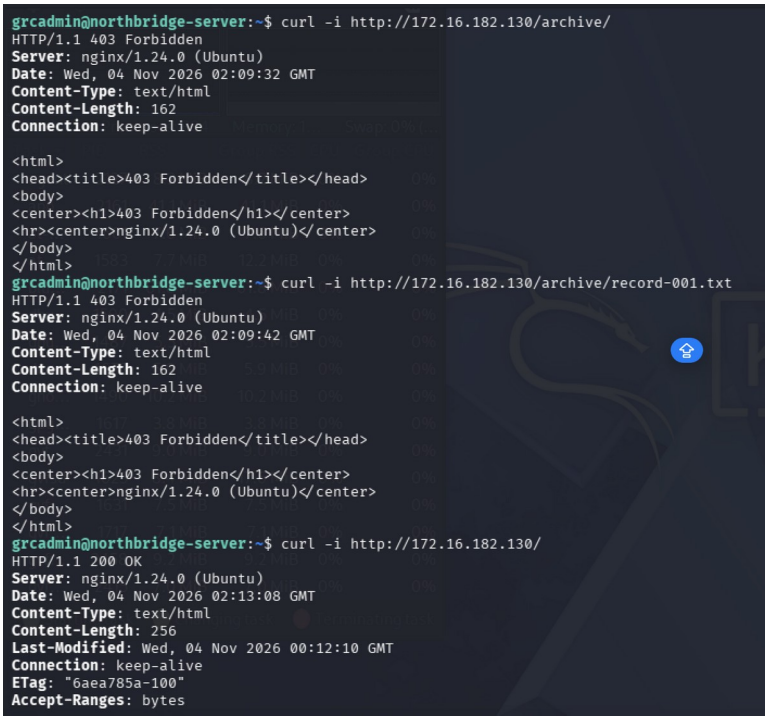


Figure A17. Request from the temporary, unapproved Kali source address timed out.

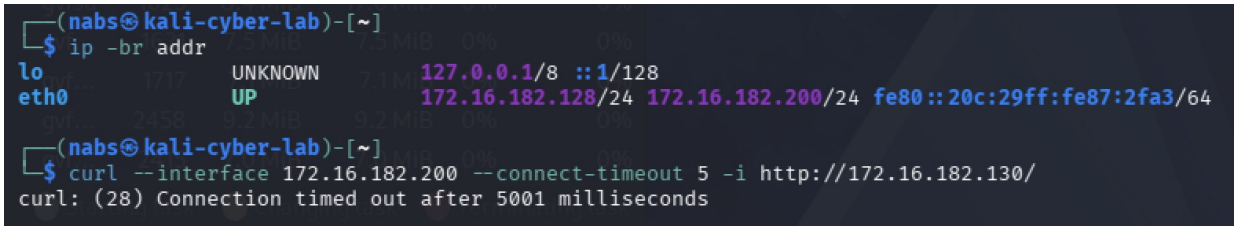


Figure A18. Local backup copy of the public portal created under /srv/grc-backups.

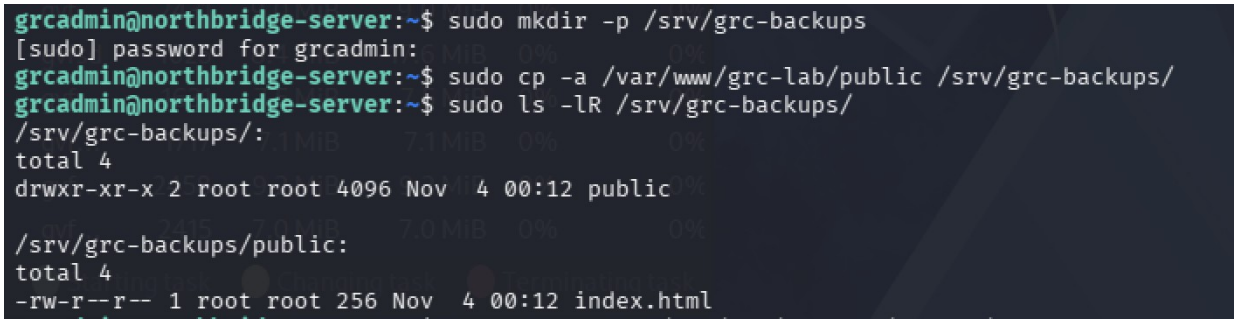


Figure A19. Portal index file restored from the backup location.

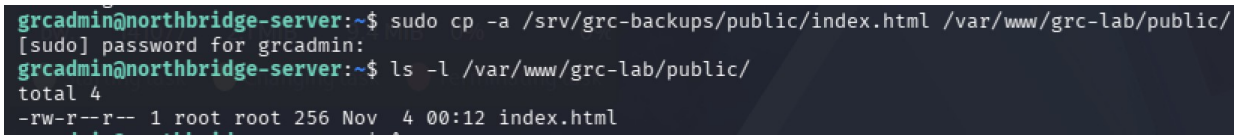


Figure A20. Recovery confirmation showing the portal content served successfully after restoration.

